Entrega final CoderHouse

Situación de análisis

La noche del 20 al 23 de junio de 2021, LexCorp fue víctima de un malware que afectó a sus servidores (Windows Server 2003/2012) y equipos de usuario (Windows 7/Windows 10) de toda la infraestructura.
Tras identificar todos los dispositivos infectados, el área de soporte técnico tomó las siguientes acciones:

- Guardaron una muestra del malware.
- Apagaron, el mismo día 23 de septiembre, las máquinas que se habían identificado como afectadas durante el incidente.
- En las máquinas que disponían de copia de seguridad (back-up), restauraron al estado correspondiente al día 19 de septiembre (fecha de último backup disponible previo al ataque). Solo un 10% del Parque contaba con backup.
- El 24 de septiembre, LexCorp solicita los servicios de un analista de ciberseguridad para analizar una muestra y emitir recomendaciones para su infraestructura de red y mejorar su postura de ciberseguridad.
- LexCorp solicita la elaboración de un informe de análisis del ataque, que tipo de malware es y el vector de ataque para aportar más detalles sobre el incidente y el nivel de compromiso derivado del mismo.

Introducción

El presente informe tiene como objetivo analizar un incidente de ciberseguridad ocurrido en la empresa LexCorp, el cual involucró la infección por malware de servidores y equipos de usuario dentro de su infraestructura tecnológica. El ataque tuvo impacto sobre distintos sistemas operativos y evidenció debilidades en los controles de seguridad existentes.

En base al análisis realizado, se evalúan las acciones llevadas a cabo por el área de soporte técnico tras el incidente, identificando aquellas que resultaron correctas, parcialmente correctas o incorrectas desde una perspectiva técnica y forense. Finalmente, se presenta una propuesta de mejora orientada a fortalecer la postura de ciberseguridad de la organización y reducir la probabilidad de incidentes similares en el futuro.

Alcance

El alcance del presente informe se limita al análisis del incidente ocurrido, la evaluación de las acciones posteriores al ataque y la propuesta de mejoras preventivas, sin incluir la implementación práctica de las soluciones.

Análisis técnico del incidente

Sistemas afectados

La infraestructura de LexCorp contaba con servidores y estaciones de trabajo que operaban bajo distintos sistemas operativos. Entre los sistemas afectados se identificaron servidores con **Windows Server 2003 y Windows Server 2012**, así como equipos de usuario final con **Windows 7 y Windows 10**.

Los servidores comprometidos cumplían un rol crítico dentro de la organización, por lo que su afectación implicó un alto riesgo operativo y de seguridad. La infección de estaciones de trabajo de usuarios incrementó la probabilidad de propagación lateral del malware dentro de la red corporativa.

Cabe destacar que la presencia de sistemas operativos desactualizados, como Windows Server 2003 y Windows 7, representa una superficie de ataque elevada, dado que estos sistemas no cuentan con soporte ni parches de seguridad vigentes.

Análisis de la Muestra de Malware

Para el presente informe se analizó una muestra del malware obtenida tras el incidente de seguridad ocurrido en la infraestructura de LexCorp. El análisis realizado fue de tipo **dinámico**, ejecutando la muestra en un entorno controlado con el objetivo de observar su comportamiento y posibles efectos sobre el sistema.

La muestra fue identificada mediante el hash **MD5: 723e114a3b04ae46c9542647e19682f8**, garantizando su correcta identificación durante el proceso de análisis. Dicho análisis se llevó a cabo en una **máquina virtual aislada**, evitando cualquier interacción con la red productiva de la organización.

Los resultados obtenidos durante la ejecución del malware se documentan a continuación mediante capturas y tablas descriptivas que detallan su comportamiento y características principales.

Campo	**Valor**
Nombre de la muestra	modificar_usuarios.ps1
Hash MD5	723e114a3b04ae46c9542647e19682f8
Tipo de archivo	Script PowerShell
Tipo de análisis	Dinámico

Información estática encontrada

- **NAMES**: modificar_usuarios.ps1
- **MD5**: 723e114a3b04ae46c9542647e19682f8
- **SHA-1**: 0c4232f19b7203eaf3b6b4e390ac176c88745a15
- **SHA-256**: 188596839f2390436fc8c0585820180c616c642dd1443cddd26370a1cf3e63d7
- **Vhash**: e585f3d32ab71925be6f82b7eba01f69
- **SSDEEP**: 96:mkKy/2Ptmcer6rQD7sRYRUI0ds2Ns8YNGMGMGMGMGMGMGwd1z3FgU7M6GtT1:r/2TeTfUPaSaGMGMGMGMGMGMGwd1zVKT
- **TLSH**: T1009184078E815B2787F2C3536B659040E9820439EA0C9586B0BCD44AB76238F46BF6BB
- **FILE TYPE**: Powershell
- **MAGIC**: HTML document, Unicode text, UTF-8 (with BOM) text, with CRLF line terminators
- **TRLD**: Text - UTF-8 encoded (100%)
- **MAGIKA**: POWERSHELL

El uso de PowerShell como formato del malware representa un riesgo elevado debido a su ejecución nativa en sistemas Windows y su frecuente utilización en ataques dirigidos.

Tipo de malware identificado

A partir del análisis realizado, se identificó que la muestra corresponde a un malware de tipo ransomware, implementado mediante un script PowerShell. Este tipo de amenaza se caracteriza por ejecutar acciones maliciosas sobre los sistemas comprometidos, afectando principalmente la disponibilidad de la información y de los recursos.

El uso de PowerShell como mecanismo de ejecución resulta especialmente relevante, ya que se trata de una herramienta nativa de los sistemas Windows, lo que facilita la evasión de controles de seguridad tradicionales y permite la ejecución de comandos con distintos niveles de privilegio sin requerir binarios adicionales.

En el contexto del incidente analizado, este tipo de malware representa un riesgo elevado para la infraestructura de LexCorp, debido a su potencial impacto operativo y a la posibilidad de propagación dentro de la red corporativa.

Análisis de Comportamiento de Malware

Durante el análisis dinámico de la muestra se identificó un comportamiento malicioso complejo, característico de ransomware moderno, que combina técnicas de evasión, persistencia, cifrado de información y exfiltración de datos, utilizando procesos legítimos del sistema operativo para camuflar su actividad.

Ejecución y Evasión

Durante el análisis dinámico de la muestra se observó que el malware inicia su ejecución mediante PowerShell, empleando técnicas de bypass de políticas de ejecución para permitir la ejecución de comandos sin restricciones de seguridad.

El proceso powershell.exe fue utilizado como orquestador principal del ataque, desde el cual se lanzaron múltiples procesos secundarios y scripts, permitiendo al malware operar bajo el contexto de herramientas legítimas del sistema operativo.

Entre las técnicas de evasión identificadas se destacan:

- Bypass de Execution Policy, permitiendo la ejecución de scripts PowerShell no firmados.
- Uso de procesos legítimos como **conhost.exe**, **cmd.exe** y **powershell.exe** para ocultar la actividad maliciosa.
- Ejecución de comandos desde archivos **.bat**, reduciendo la visibilidad del comportamiento malicioso.
- Verificaciones del entorno (idioma, proxy, configuraciones del sistema) para adaptar la ejecución y evitar detecciones automáticas.

Persistencia

Durante el análisis se identificaron mecanismos de persistencia utilizados por el malware con el objetivo de mantener su ejecución tras reinicios del sistema y asegurar la continuidad del ataque.
El malware empleó el Programador de Tareas de Windows (*Task Scheduler*) para crear tareas programadas que permitían la ejecución automática de componentes maliciosos.

En particular, se observó el uso de **schtasks** para registrar una tarea persistente, lo que le permitió al atacante reactivar el malware de forma silenciosa sin requerir interacción del usuario. Esta técnica reduce la visibilidad del ataque y dificulta su detección por soluciones de seguridad tradicionales.

El uso de herramientas nativas del sistema para establecer persistencia se encuadra dentro de técnicas *Living-off-the-Land*, aprovechando funcionalidades legítimas del sistema operativo con fines maliciosos.

Evasión de seguridad

Durante el análisis dinámico se identificó la ejecución de herramientas específicamente diseñadas para desactivar los mecanismos de seguridad del sistema comprometido. Entre ellas se destaca DefenderRemover.exe, descargado desde repositorios legítimos y ejecutado como parte de la cadena de ataque.

Esta herramienta fue utilizada para modificar configuraciones del sistema y deshabilitar Windows Defender, permitiendo que el resto de los componentes maliciosos se ejecutarán sin ser detectados o bloqueados. Para ello, el malware creó y ejecutó múltiples archivos auxiliares, incluyendo scripts PowerShell, archivos de registro (.reg) y archivos por lotes (.bat), los cuales realizaron cambios persistentes en la configuración de seguridad del sistema.

Asimismo, se observó el uso de PowerRun.exe, una herramienta que permite ejecutar procesos con privilegios elevados, facilitando la modificación de componentes protegidos del sistema operativo. Estas acciones corresponden a la técnica T1562.001 – Impair Defenses: Disable or Modify Tools del framework MITRE ATT&CK.

La desactivación efectiva de las defensas permitió al malware avanzar hacia las fases de cifrado y exfiltración de información sin interferencias por parte de soluciones de seguridad nativas.

PID	Process name	Filename	Content
1765	DefenderRemover.exe	C:\Users\admin\AppData\Local\Temp\7zSFC92.tmp\RemoveSecHealthApp.ps1	2Kb text
1764	DefenderRemover.exe	C:\Users\admin\AppData\Local\Temp\7zSFC92.tmp\Remove_Defender\NomoreDelayandTimeouts.reg	1Kb text
1764	DefenderRemover.exe	C:\Users\admin\AppData\Local\Temp\7zSFC92.tmp\Remove_Defender\Output.reg	23Kb text
1764	DefenderRemover.exe	C:\Users\admin\AppData\Local\Temp\7zSFC92.tmp\Remove_Defender\RemoveShellAssociation.reg	1Kb text
1764	DefenderRemover.exe	C:\Users\admin\AppData\Local\Temp\7zSFC92.tmp\Remove_SecurityComp\Remove_SecurityComp.reg	13Kb text
1764	DefenderRemover.exe	C:\Users\admin\AppData\Local\Temp\7zSFC92.tmp\Script_Run.bat	9Kb text
1764	DefenderRemover.exe	C:\Users\admin\AppData\Local\Temp\7zSFC92.tmp\PowerRun.exe	**executable**

Impacto del Malware

El análisis del comportamiento del malware evidenció un impacto significativo tanto en la **disponibilidad** como en la **confidencialidad** de la información. Durante la fase final del ataque, el malware ejecutó **ccrypt.exe** para cifrar archivos del sistema, provocando la indisponibilidad de datos críticos y afectando la continuidad operativa.

Paralelamente, se identificó la **exfiltración de información sensible** mediante el abuso del proceso legítimo **certutil.exe**, el cual estableció múltiples conexiones externas hacia infraestructura controlada por el atacante. Estas conexiones fueron utilizadas para transferir archivos comprimidos con información confidencial fuera del entorno comprometido, como se detalla en la tabla de conexiones maliciosas.

Protocol	PID	Process name	CN	IP	Port	ASN
TCP	7856	certutil.exe	EE.UU	170.130.165.73	80	AS62904
TCP	7964	certutil.exe	Alemania	79.132.130.211	80	-
TCP	8056	certutil.exe	Alemania	45.11.181.44	80	M247 Ltd

Asimismo, se observaron solicitudes DNS hacia dominios legítimos como **GitHub** y **SourceForge**, utilizados para la descarga de herramientas maliciosas necesarias para la ejecución del ataque. Esta técnica permite camuflar la actividad maliciosa dentro de tráfico confiable y facilitar la ejecución de las etapas posteriores del malware.

Status	Domain	IP
Responded	github.com	140.82.121.3
Responded	objects.githubusercontent.com	185.199.111.133 185.199.108.133 185.199.110.133 185.199.109.133
Responded	raw.githubusercontent.com	185.199.108.133 185.199.111.133 185.199.110.133 185.199.109.133
Responded	ccrypt.sourceforge.net	104.18.12.149 104.18.13.149

En conjunto, estas acciones confirman que el incidente corresponde a un **ransomware con capacidades de doble impacto**, combinando cifrado de información y filtración de datos, elevando de forma considerable el nivel de compromiso de la infraestructura de LexCorp.

Evaluación de las acciones del Área de TI

Tras el incidente de malware en la infraestructura de LexCorp, el área de soporte técnico llevó a cabo varias acciones para mitigar los efectos del ataque. A continuación, se evalúan dichas acciones desde una perspectiva técnica y forense, identificando las que fueron correctas, parcialmente correctas o incorrectas.

Acciones Correctas

Preservación de la muestra del malware

- Guardar la muestra identificada mediante MD5 (723e114a3b04ae46c9542647e19682f8) permitió su análisis dinámico y forense.
- Esta acción es fundamental para comprender el vector de ataque, las técnicas de evasión y el impacto del malware.

Acciones Parcialmente Correctas

Apagado de los equipos afectados

- **Bien:** Contuvo la propagación del malware dentro de la red corporativa.
- **Mal:** La desconexión inmediata implicó la pérdida de evidencia volátil, como procesos activos, memoria RAM y conexiones de red, que podrían haber aportado información sobre la cadena de ataque y exfiltración de datos.

Acciones Incorrectas / Críticas

Restauración desde backups insuficientes

- Solo el 10% del parque contaba con copias de seguridad, dejando la mayoría de los sistemas sin posibilidad de restauración inmediata.
- La fecha de restauración indicada (19 de septiembre) no coincide con el periodo del ataque (20–23 de junio), lo que sugiere que los backups podrían no haber estado actualizados o incluso contener elementos comprometidos.
- Falta de política de backups robusta (regla 3-2-1), dejando a la organización vulnerable a pérdida de datos.

Propuesta de mejora

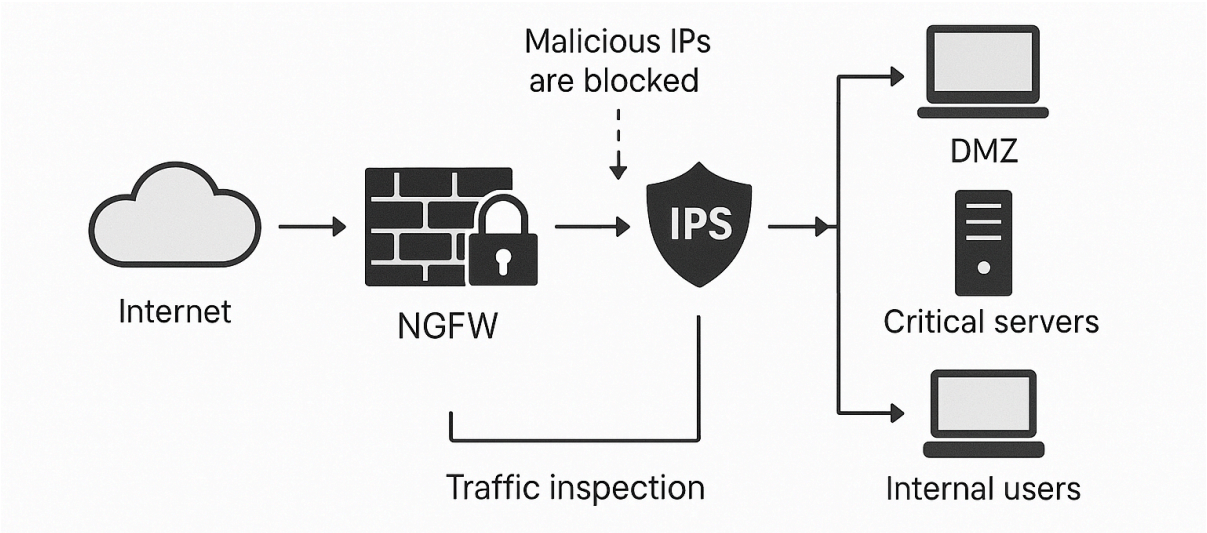
Para proteger a LexCorp contra incidentes similares al analizado, se propone la **implementación de soluciones técnicas integrales** en toda la infraestructura:

Next-Generation Firewall (NGFW) con IPS

Funciones y reglas recomendadas:

- **Filtrado de tráfico por IP y puerto:**
  - Solo permite puertos y protocolos estrictamente necesarios.
  - Bloquear puertos no utilizados para minimizar superficie de ataque (ej: Telnet, SMBv1).
- **Inspección de tráfico de aplicaciones:**
  - Permite detectar malware camuflado en tráfico HTTP/HTTPS.
  - Activar Deep Packet Inspection (DPI) para filtrar contenido sospechoso.
- **Prevención de intrusiones (IPS):**
  - Detecta patrones de ataque conocidos, exploits y anomalías en la red.
  - Actualizar firmas periódicamente y configurar alertas automáticas para actividad sospechosa.
- **Segmentación de red y zonas de seguridad:**
  - Crear VLAN o zonas diferenciadas: servidores críticos, usuarios internos, DMZ.
  - Limitar el tráfico entre zonas según necesidad ("principio de menor privilegio").

Fundamento: Durante el ataque, el malware filtró archivos mediante certutil.exe y pudo interactuar con múltiples IPs externas. Un NGFW correctamente configurado habría bloqueado estas conexiones y detectado anomalías en tiempo real.

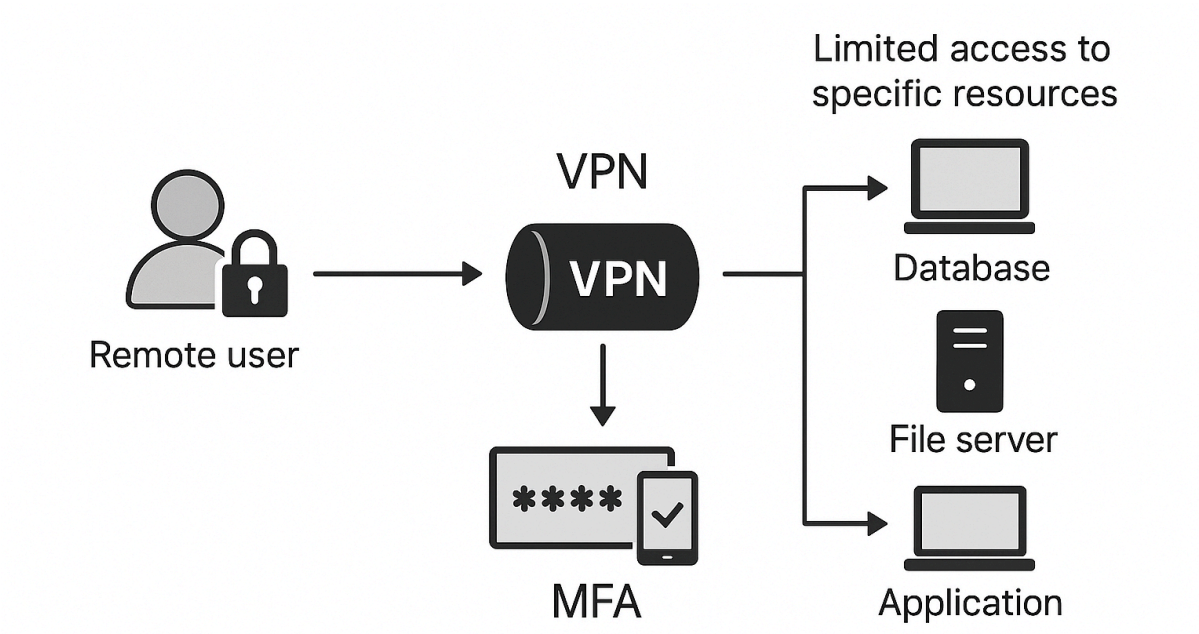


VPN Segura y Control de Acceso Remoto

Recomendaciones:

- **Autenticación fuerte:**
  - MFA (Multi-Factor Authentication) obligatorio para todos los accesos remotos.
  - Certificados digitales para autenticar clientes VPN.
- **Cifrado robusto:**
  - Usar protocolos seguros como **IPSec o SSL/TLS**.
  - Evitar protocolos obsoletos o inseguros (ej: PPTP).
- **Política de acceso segmentado:**
  - Cada usuario o grupo solo puede acceder a los recursos necesarios.
  - Registro y monitoreo de todas las conexiones VPN para detectar patrones anómalos.
- **Actualización y mantenimiento:**
  - Mantener servidores VPN y clientes siempre actualizados.
  - Revisar logs de conexión periódicamente para auditoría y análisis de seguridad.

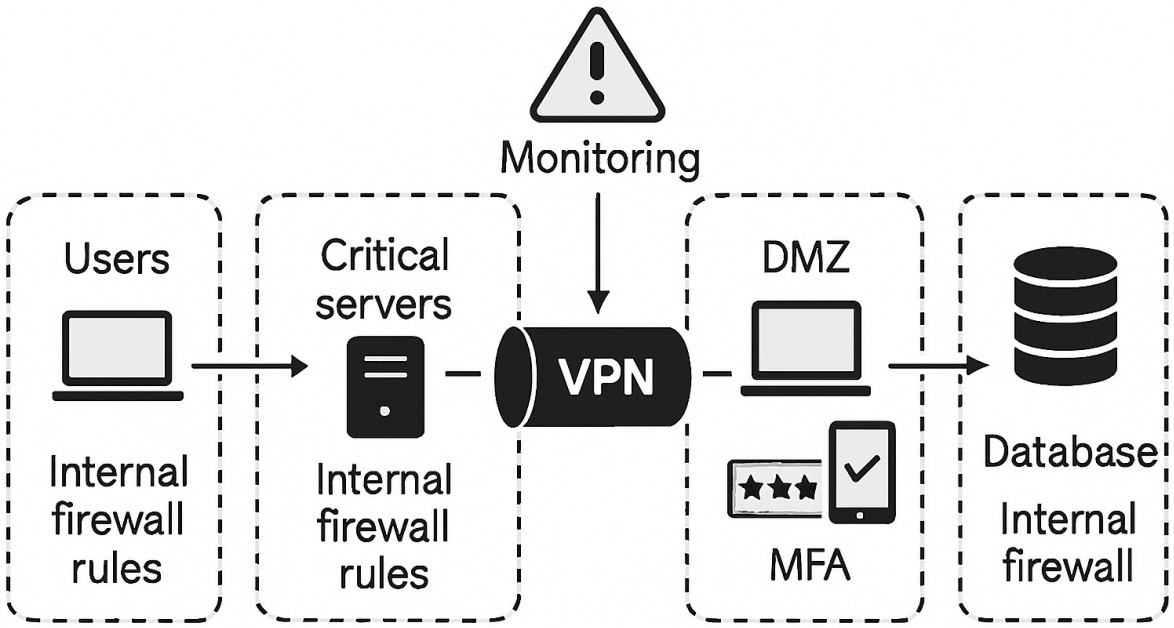
Fundamento: Una VPN mal configurada o sin control de acceso segmentado podría permitir que un atacante externo ingrese a la red interna y despliegue malware. La combinación de MFA, cifrado y monitoreo reduce significativamente este riesgo.



Control de Acceso y Políticas de Red

- **Principio de menor privilegio:**
  - Los usuarios y servicios solo tienen permisos estrictamente necesarios.
- **Reglas de firewall internas:**
  Limitar el tráfico entre estaciones de trabajo y servidores críticos.
  - Supervisar conexiones salientes para detectar posibles exfiltraciones.
- **Monitoreo continuo:**
  - Alertas ante tráfico anómalo, intentos de conexión a servidores externos sospechosos o puertos inusuales.

Fundamento: Durante el ataque, la exfiltración de datos y la propagación lateral habrían sido limitadas si se aplicaran segmentación, reglas estrictas de firewall y monitoreo proactivo.

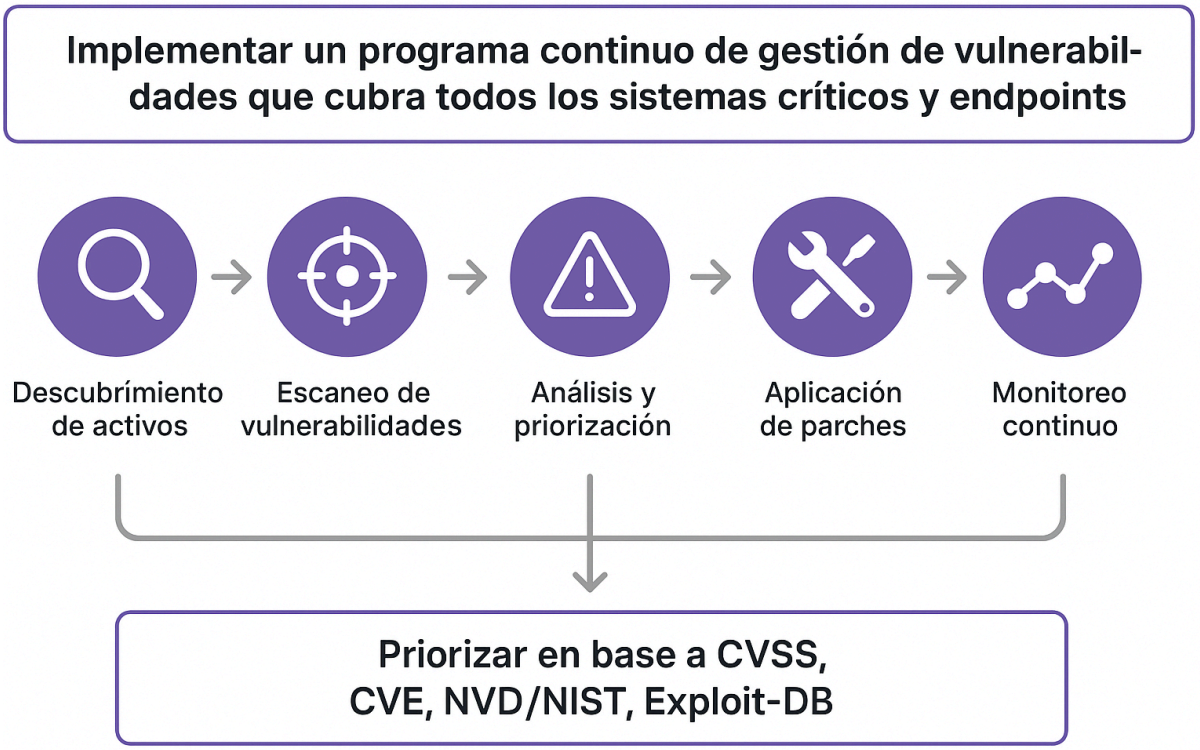


Programas de Gestión de Vulnerabilidades y Parcheo Ágil

Para fortalecer la postura de seguridad de LexCorp, se recomienda implementar un programa continuo de gestión de vulnerabilidades que cubra todos los sistemas críticos y endpoints. El programa seguirá un ciclo estructurado: descubrimiento de activos → escaneo de vulnerabilidades → análisis y priorización → aplicación de parches → monitoreo continuo.

La priorización se basará en CVSS (Common Vulnerability Scoring System) y en referencias de bases de datos como CVE, NVD/NIST y Exploit-DB, asegurando que las vulnerabilidades más críticas sean remediadas de manera rápida y efectiva.

Este enfoque permite reducir la superficie de ataque, mitigar riesgos de exploits conocidos y garantizar trazabilidad de todas las acciones correctivas para auditorías y análisis forense.



El programa puede apoyarse en herramientas de escaneo como Nessus o OpenVAS, gestión centralizada con Qualys o Rapid7, y despliegue ágil de parches mediante WSUS/SCCM, mientras que un SIEM como Splunk permite monitoreo continuo y alertas sobre vulnerabilidades críticas.

Programa de concientización

El factor humano es el eslabón más débil en la ciberseguridad, siendo responsable de más del 80 % de los incidentes, según reportes de Verizon DBIR 2025 y estudios de KnowBe4. Para mitigar este riesgo, LexCorp deberá implementar un programa integral de concientización y entrenamiento anti-phishing, liderado por el equipo de seguridad de la información o de TI.

El programa incluirá:

- Campañas educativas periódicas, enseñando a identificar correos y enlaces maliciosos.
- Simulaciones controladas de phishing, para medir la reacción de los usuarios y reforzar el aprendizaje.
- Métricas de desempeño, como tasa de clics en correos de prueba y reportes de emails sospechosos, para ajustar el programa continuamente.

El objetivo es convertir al usuario en la primera línea de defensa, reduciendo la probabilidad de que errores humanos permitan la entrada de malware, ransomware o el robo de credenciales críticas.

Políticas de Backups

Para garantizar la disponibilidad de datos y minimizar el impacto de futuros incidentes, LexCorp implementará una política de backups obligatoria basada en la regla 3-2-1:

- 3 copias de los datos: producción + 2 backups.
- 2 medios diferentes: almacenamiento local + almacenamiento externo/cloud.
- 1 copia fuera del sitio: remoto o en la nube, protegida contra ransomware y desastres.

Se integrará esta política con el plan de continuidad de negocio, asegurando restauraciones rápidas y pruebas periódicas para validar la integridad de los backups.

Objetivo: Reducir drásticamente el impacto de malware, ransomware u otros incidentes que comprometan la disponibilidad de la información crítica.

Conclusión

El análisis del incidente ocurrido en LexCorp permitió identificar que la infraestructura fue comprometida por un ransomware distribuido mediante PowerShell, el cual ejecutó técnicas avanzadas de evasión de seguridad, persistencia y exfiltración de información. La reconstrucción del ataque, apoyada en el mapeo MITRE ATT&CK y los resultados del análisis dinámico, evidenció el alto nivel de compromiso alcanzado y la capacidad del malware para utilizar procesos legítimos del sistema y desactivar defensas nativas.

La evaluación de las acciones del área de soporte técnico mostró que:

- La captura de la muestra fue correcta y permitió el análisis forense.
- El apagado de equipos fue parcialmente correcto, pues contenía la propagación pero afectó la evidencia volátil.
- La restauración desde backup, aunque conceptualmente correcta, reveló una cobertura insuficiente y posibles inconsistencias en la fecha de restauración.

La propuesta de mejora presentada abarca tanto la prevención de incidentes como la resiliencia operativa, incluyendo:

- Implementación de NGFW con IPS, VPN segura y políticas de acceso.
- Programa de concientización y entrenamiento del factor humano.
  Políticas de backup y continuidad de negocio.
- Plan de respuesta a incidentes (IRP) que asegura detección, contención, erradicación y recuperación.

En conjunto, estas medidas fortalecen la postura de ciberseguridad de LexCorp, reduciendo la probabilidad de compromisos futuros, asegurando la integridad de los datos y mejorando la capacidad de reacción ante incidentes. Este caso enfatiza la importancia de combinar tecnología, procesos y concientización humana para proteger la infraestructura corporativa frente a amenazas avanzadas.